

Volume 2: Options, Settings, Profile & Avatar Customization

Detailed technical specification for user profile management, match history analytics, 6-layer avatar customization engine, client settings persistence, TOTP 2FA, and session security.

Target Stack: NestJS 11 · Argon2 · Speakeasy TOTP · Prisma 6 · Zustand · Lead: Muhammad Sameer Ali

VOLUME OBJECTIVE:
Specifies the complete player identity, profile statistics, 6-layer avatar studio, sound/performance preferences, and enterprise account security architecture (TOTP two-factor, email OTP verification, password policies, and instant session revocation).

1. Player Profile & Historical Match Analytics

- **Profile Endpoint:** GET /me/profile returns user details, Solana deposit address, wallet balance, equipped cosmetics, and lifetime stats.
- **Stats Metrics:** Matches Played, Total Wins, Win Rate Percentage, Average Turn Duration, Best Winning Streak, Total USDT Won.
- **Match History:** GET /me/history returns paginated historical matches with opponent details, final counts, prize payouts, and skill usage records.

2. 6-Layer Avatar Customization Studio

The avatar studio (app/avatar/page.tsx & MasterAvatar.tsx) composites 6 modular visual layers:

Layer Slot	Layer Description & Assets	Equip & Ownership Validation
1. Head / Hat	Cow horns, crowns, caps, viking helmets, cyberpunk visors.	Stored in cosmeticsJson.head; validated against cosmeticsOwned.
2. Eyes / Glasses	Sunglasses, laser eyes, monocles, retro frames, eye patches.	Stored in cosmeticsJson.eyes.
3. Outfit / Cloth	Arcade jerseys, suits, hoodies, armor vests, Hawaiian shirts.	Stored in cosmeticsJson.cloth.
4. Shoes / Kicks	Sneakers, boots, golden hooves, hover shoes.	Stored in cosmeticsJson.shoes.
5. Board / Arena	Neon grid, wood pasture, obsidian slab, gold trim board.	Stored in cosmeticsJson.board.
6. Card Back	Classic 31, Cyber holographic, Dragon scales, Golden cow skin.	Stored in cosmeticsJson.cardBack.

3. Account Security, MFA & Password Policies

- **TOTP 2FA:** POST /auth/mfa/setup generates base32 secret and QR code. Secret is encrypted at rest using AES-256-GCM (secret-box). POST /auth/mfa/verify enables 2FA and outputs 8 hashed one-time recovery codes.
- **Email OTP Verification:** POST /auth/email/send-code sends 6-digit OTP (15-min TTL, argon2 hash). POST /auth/email/verify flips emailVerifiedAt.
- **Token Revocation:** Every access token carries tokenVersion. On password change, logout-all, or ban, tokenVersion is incremented, instantly invalidating all issued tokens.

4. Client Preferences & Audio Settings

Settings (useSettingsStore) are synced locally and to user DB: Sound FX mute/volume, BGM volume, Low Performance Mode (disables intensive shaders on mobile), Ping Monitor toggle, Language locale.